

CYBER SECURITY & ETHICAL HACKING – EPICODE

REPORT D'ESAME

Progetto Settimanale

Esercitazione di Esame

A cura di:

Nicola Madonna

Epicode

4 settembre 2026

Esercizio 1: Usare Windows PowerShell

Parte 2: Esplorare i comandi del Prompt dei Comandi e di PowerShell

Il comando `dir` è stato eseguito sia in PowerShell sia nel Prompt dei Comandi, nella stessa directory utente.

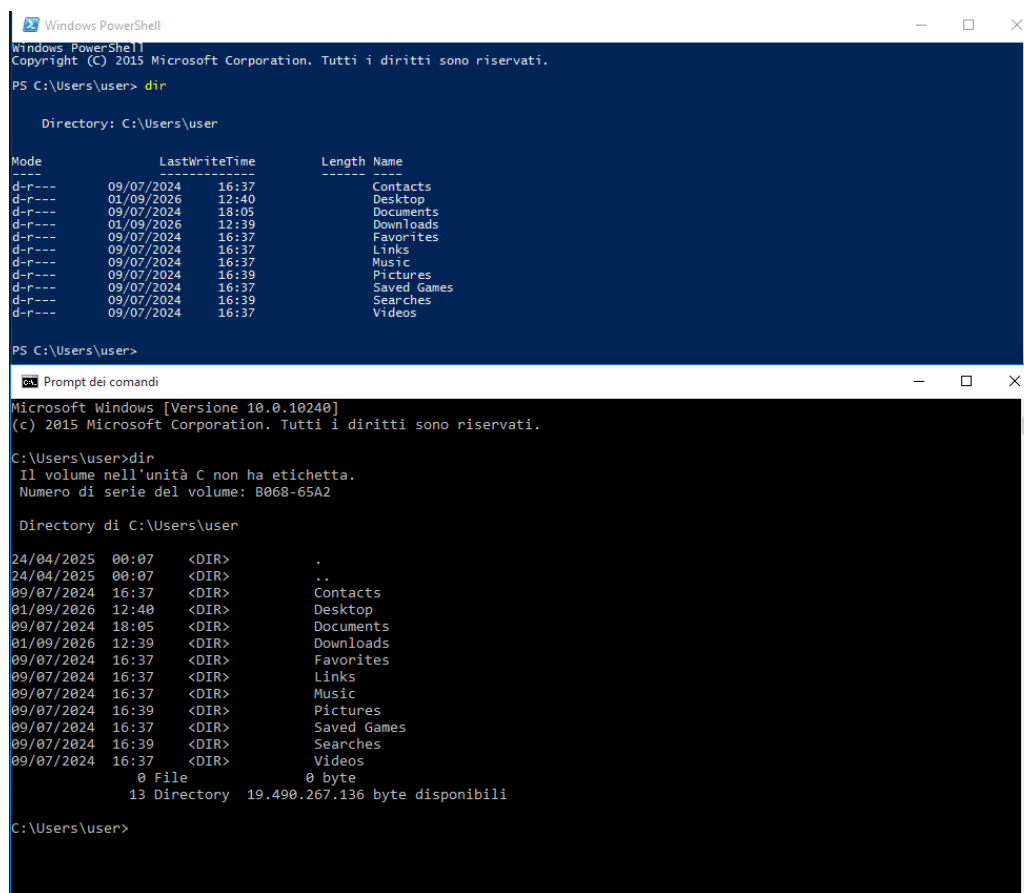
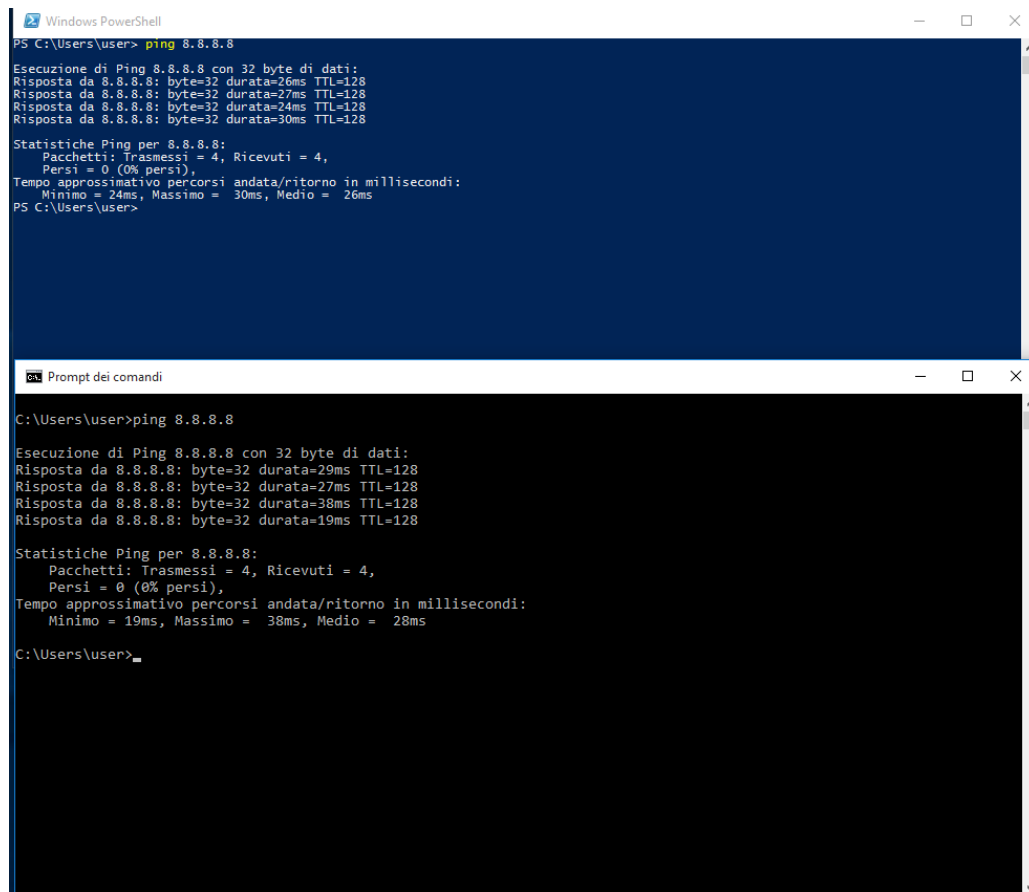


Figura 1: Confronto tra l'output di `dir` in PowerShell e nel Prompt dei Comandi.

Domanda: Quali sono gli output del comando `dir`?

Risposta: Il comando `dir` produce output diversi a seconda della shell in cui viene eseguito, pur elencando lo stesso contenuto della cartella `C:\Users\user`. In PowerShell, `dir` è un alias del cmdlet `Get-ChildItem` e restituisce un output tabellare con le colonne `Mode`, `LastWriteTime`, `Length` e `Name`, in stile "a oggetti" tipico di PowerShell. Nel Prompt dei Comandi (`cmd.exe`), `dir` è invece un comando nativo che produce un output testuale in stile legacy, che include informazioni aggiuntive assenti in PowerShell: l'etichetta del volume, il numero di serie del volume, il conteggio di file e directory, e lo spazio disponibile su disco in byte.



```
PS C:\Users\user> ping 8.8.8.8

Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=26ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=27ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=24ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=30ms TTL=128

Statistiche Ping per 8.8.8.8:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 24ms, Massimo = 30ms, Medio = 26ms
PS C:\Users\user>
```

```
C:\Users\user>ping 8.8.8.8

Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=29ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=27ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=38ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=19ms TTL=128

Statistiche Ping per 8.8.8.8:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 19ms, Massimo = 38ms, Medio = 28ms
C:\Users\user>
```

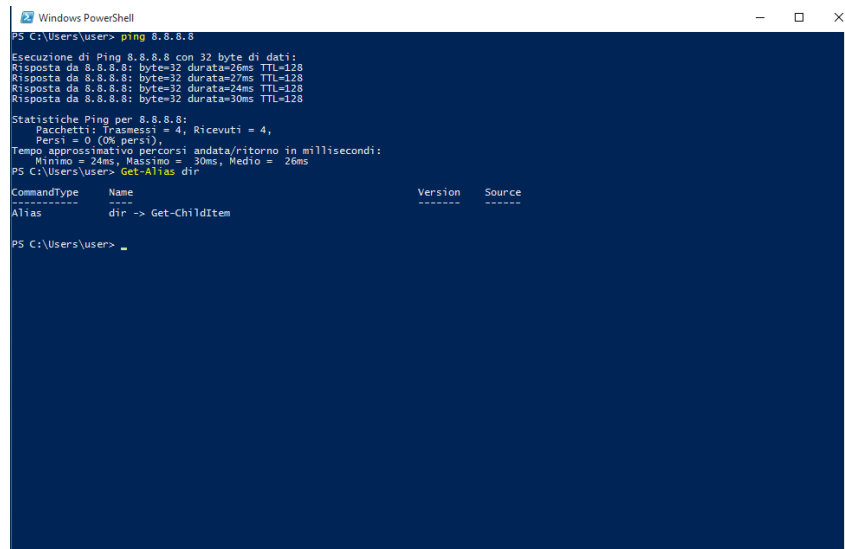
Figura 2: Esecuzione di `ping 8.8.8.8` in PowerShell e nel Prompt dei Comandi.

Domanda: Prova un altro comando che hai usato nel prompt dei comandi, come `ping`, `cd` e `ipconfig`. Quali sono i risultati?

Risposta: Eseguendo `ping 8.8.8.8` sia in PowerShell sia nel Prompt dei Comandi, l'output risulta identico in entrambe le shell (stesse statistiche di pacchetti trasmessi/ricevuti e tempi minimo/massimo/medio). Questo accade perché `ping.exe` è un eseguibile nativo di Windows, richiamato allo stesso modo da entrambe le shell: a differenza di `dir` (che in PowerShell è un alias di un cmdlet), `ping` non dispone di un cmdlet PowerShell dedicato e viene quindi eseguito come processo esterno identico in entrambi i contesti. Lo stesso comportamento si osserva generalmente anche con altri comandi esterni come `ipconfig`.

Parte 3: Esplorare i cmdlet

Per identificare il comando PowerShell equivalente a `dir`, è stato eseguito `Get-Alias dir`.



```

Windows PowerShell
PS C:\Users\user> ping 8.8.8.8

Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=26ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=27ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=24ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=30ms TTL=128

Statistiche Ping per 8.8.8.8:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 24ms, Massimo = 30ms, Medio = 26ms
PS C:\Users\user> Get-Alias dir

CommandType      Name
-----
Alias             dir -> Get-ChildItem

PS C:\Users\user>

```

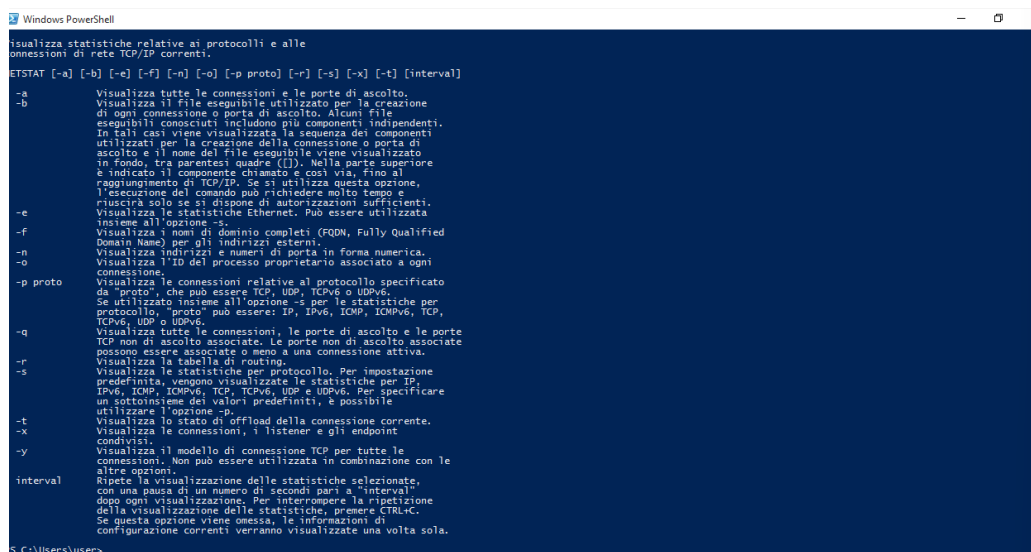
Figura 3: Output di Get-Alias dir.

Domanda: Qual è il comando PowerShell per dir?

Risposta: Get-ChildItem. L'output di Get-Alias dir conferma infatti che dir è un alias (dir -> Get-ChildItem) del cmdlet nativo di PowerShell.

Parte 4: Esplorare il comando netstat usando PowerShell

Sono state consultate le opzioni disponibili per il comando netstat tramite netstat -h.



```

Windows PowerShell
Visualizza statistiche relative ai protocolli e alle
connessioni di rete TCP/IP correnti.

NETSTAT [-a] [-b] [-e] [-f] [-n] [-o] [-p proto] [-r] [-s] [-x] [-t] [interval]

-a
Visualizza tutte le connessioni e le porte di ascolto.
-b
Visualizza il file eseguibile utilizzato per la creazione
di ogni connessione o porta di ascolto. Alcuni file
eseguibili conosciuti includono più componenti indipendenti.
In tali casi viene visualizzata la sequenza dei componenti
utilizzati per la creazione della connessione o porta di
ascolto e il nome del file eseguibile viene visualizzato
in fondo, tra parentesi quadre ([]). Nella parte superiore
è indicato il componente chiamato e così via, fino al
raggiungimento di TCP/IP. Se si utilizza questa opzione,
l'esecuzione del comando può richiedere molto tempo e
riuscirà solo se si dispone di autorizzazioni sufficienti.
Visualizza le statistiche Ethernet. Può essere utilizzata
insieme all'opzione -s.
-f
Visualizza i nomi di dominio completi (FQDN, Fully Qualified
Domain Name) per gli indirizzi esterni.
-n
Visualizza indirizzi e numeri di porta in forma numerica.
-o
Visualizza l'ID del processo proprietario associato a ogni
connessione.
-p proto
Visualizza le connessioni relative al protocollo specificato
da "proto", che può essere TCP, UDP, TCPv6 o UDPv6.
Se utilizzato insieme all'opzione -s per le statistiche per
protocollo, "proto" può essere: IP, IPv6, ICMP, ICMPv6, TCP,
TCPv6, UDP o UDPv6.
-q
Visualizza tutte le connessioni, le porte di ascolto e le porte
TCP non di ascolto associate. Le porte non di ascolto associate
possono essere associate o meno a una connessione attiva.
-r
Visualizza la tabella di routing.
-s
Visualizza le statistiche per protocollo. Per impostazione
predefinita, vengono visualizzate le statistiche per IP,
IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP e UDPv6. Per specificare
un sottoinsieme dei valori predefiniti, è possibile
utilizzare l'opzione -p.
-t
Visualizza lo stato di offload della connessione corrente.
-x
Visualizza le connessioni, i listener e gli endpoint
condivisi.
-y
Visualizza il modello di connessione TCP per tutte le
connessioni. Non può essere utilizzata in combinazione con le
altre opzioni.
interval
Ripete la visualizzazione delle statistiche selezionate,
con una pausa di un numero di secondi pari a "interval".
dopo ogni visualizzazione. Per interrompere la ripetizione
della visualizzazione delle statistiche, premere CTRL+C.
Se questa opzione viene omessa, le informazioni di
configurazione correnti verranno visualizzate una volta sola.

S C:\Users\user>

```

Figura 4: Output di netstat -h con l'elenco delle opzioni disponibili.

Successivamente è stata visualizzata la tabella di routing con netstat -r.

```

Windows PowerShell
PS C:\Users\user> netstat -r

=====
Elenco interfacce
4...08 00 27 ba b1 9f .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
5...00 00 00 00 00 00 e0 Microsoft Teredo Tunneling Adapter
3...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter #2
=====

IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia Metrica
  0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15    10
  10.0.2.0            255.255.255.0 On-link      10.0.2.15    266
  10.0.2.15           255.255.255.255 On-link      10.0.2.15    266
  10.0.2.255          255.255.255.255 On-link      10.0.2.15    266
  127.0.0.0           255.0.0.0  On-link      127.0.0.1    306
  127.0.0.1           255.255.255.255 On-link      127.0.0.1    306
  127.255.255.255     255.255.255.255 On-link      127.0.0.1    306
  224.0.0.0           240.0.0.0  On-link      127.0.0.1    306
  224.0.0.0           240.0.0.0  On-link      10.0.2.15    266
  255.255.255.255     255.255.255.255 On-link      127.0.0.1    306
  255.255.255.255     255.255.255.255 On-link      10.0.2.15    266
=====
Route permanenti:
Nessuna

IPv6 Tabella route
=====
Route attive:
  Interf Metrica Rete Destinazione      Gateway
  5      306  ::/0                On-link
  1      306  ::1/128           On-link
  5      306  2001::/32           On-link
  5      306  2001:0:4625:9904:38f0:2ebd:b0c7:7fa7/128 On-link
  5      306  fe80::/64             On-link
  5      306  fe80::38f0:2ebd:b0c7:7fa7/128 On-link
  1      306  ff00::/8                On-link
  5      306  ff00::/8                On-link
=====
Route permanenti:
Nessuna
PS C:\Users\user>

```

Figura 5: Tabella di routing IPv4/IPv6 ottenuta con `netstat -r`.

Domanda: Qual è il gateway IPv4?

Risposta: Dalla tabella di routing IPv4 ottenuta con `netstat -r`, il gateway per la rotta di default (0.0.0.0) è **10.0.2.2**, raggiungibile tramite l'interfaccia con indirizzo 10.0.2.15.

È stata quindi aperta una seconda finestra PowerShell con privilegi elevati, dalla quale eseguire `netstat -abno` per visualizzare i processi associati alle connessioni TCP attive.

```
PS C:\Windows\system32> netstat -abho

Visualizza statistiche relative ai protocolli e alle
connessioni di rete TCP/IP correnti.

NETSTAT [-a] [-b] [-e] [-f] [-n] [-o] [-p proto] [-r] [-s] [-x] [-t] [interval]

-a          Visualizza tutte le connessioni e le porte di ascolto.
-b          Visualizza il file eseguibile utilizzato per la creazione
            di ogni connessione o porta di ascolto. Alcuni file
            eseguibili conosciuti includono più componenti indipendenti.
            In tali casi viene visualizzata la sequenza dei componenti
            utilizzati per la creazione della connessione o porta di
            ascolto e il nome del file eseguibile viene visualizzato
            in fondo, tra parentesi quadre ([]). Nella parte superiore
            è indicato il componente chiamato e così via, fino al
            raggiungimento di TCP/IP. Se si utilizza questa opzione,
            l'esecuzione del comando può richiedere molto tempo e
            riuscirà solo se si dispone di autorizzazioni sufficienti.
-e          Visualizza le statistiche Ethernet. Può essere utilizzata
            insieme all'opzione -s.
-f          Visualizza i nomi di dominio completi (FQDN, Fully Qualified
            Domain Name) per gli indirizzi esterni.
-n          Visualizza indirizzi e numeri di porta in forma numerica.
-o          Visualizza l'ID del processo proprietario associato a ogni
            connessione.
-p proto    Visualizza le connessioni relative al protocollo specificato
            da "proto", che può essere TCP, UDP, TCPv6 o UDPv6.
            Se utilizzato insieme all'opzione -s per le statistiche per
            protocollo, "proto" può essere: IP, IPv6, ICMP, ICMPv6, TCP,
            TCPv6, UDP o UDPv6.
-q          Visualizza tutte le connessioni, le porte di ascolto e le porte
            TCP non di ascolto associate. Le porte non di ascolto associate
            possono essere associate o meno a una connessione attiva.
-r          Visualizza la tabella di routing.
-s          Visualizza le statistiche per protocollo. Per impostazione
            predefinita, vengono visualizzate le statistiche per IP,
            IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP e UDPv6. Per specificare
            un sottoinsieme dei valori predefiniti, è possibile
            utilizzare l'opzione -p.
-t          Visualizza lo stato di offload della connessione corrente.
-x          Visualizza le connessioni, i listener e gli endpoint
            condivisi.
-y          Visualizza il modello di connessione TCP per tutte le
            connessioni. Non può essere utilizzata in combinazione con le
            altre opzioni.
interval    Ripete la visualizzazione delle statistiche selezionate,
            con una pausa di un numero di secondi pari a "interval"
            dopo ogni visualizzazione. Per interrompere la ripetizione
            della visualizzazione delle statistiche, premere CTRL+C.
            Se questa opzione viene omessa, le informazioni di
            configurazione correnti verranno visualizzate una volta sola.

PS C:\Windows\system32> _
```

Figura 6: Tentativo di esecuzione del comando `netstat` da PowerShell con privilegi elevati.

Nota: nello screenshot il comando è stato digitato come `netstat -abho` invece di `netstat -abno`, un refuso che ha fatto sì che PowerShell restituisse nuovamente la schermata di aiuto delle opzioni anziché l'elenco delle connessioni attive con i relativi PID.

Infine, tramite Gestione Attività, è stato individuato uno dei PID risultanti e ne sono state esaminate le proprietà.

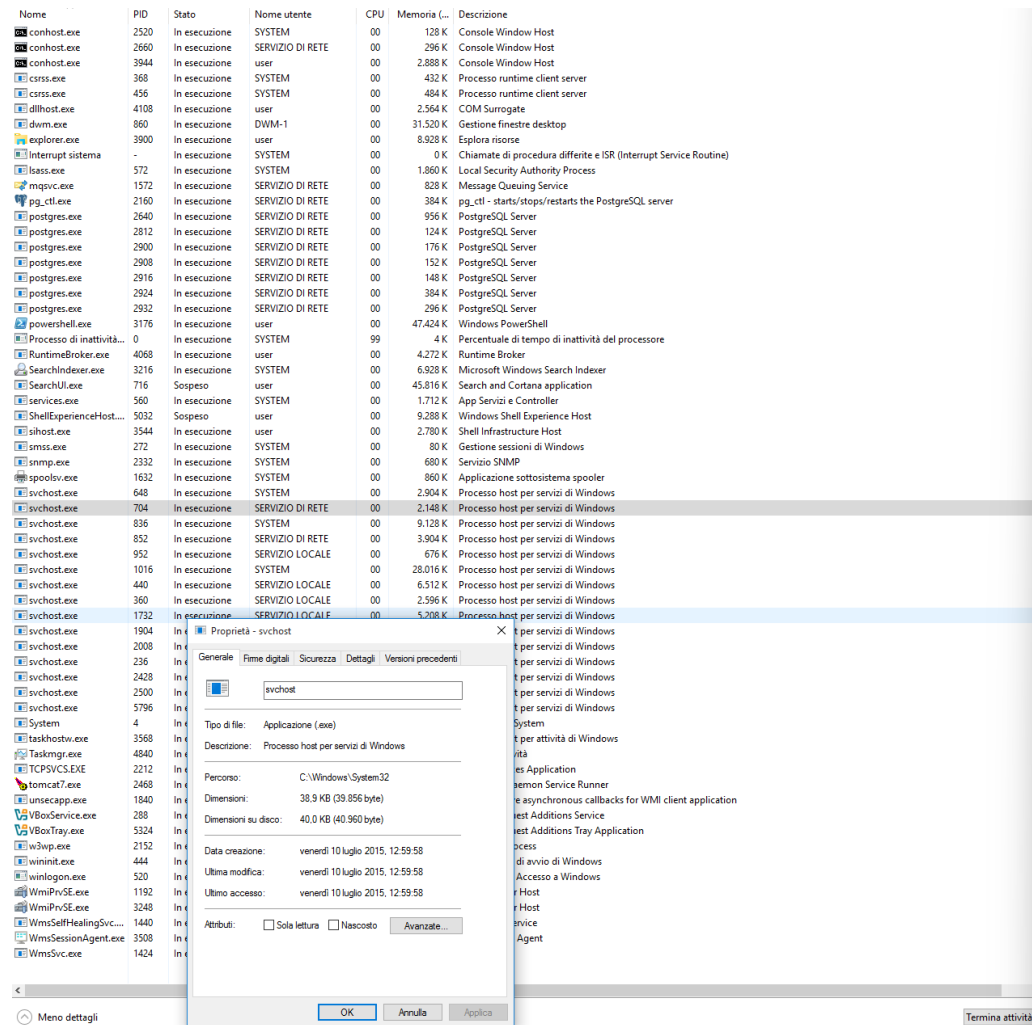


Figura 7: Scheda Dettagli di Gestione Attività e finestra Proprietà del processo `svchost.exe`.

Domanda: Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Risposta: Dalla scheda Dettagli di Gestione Attività è possibile ottenere, per il PID selezionato: il nome del processo, il PID stesso, lo stato di esecuzione, l'utente che lo ha avviato, l'utilizzo di CPU e memoria e una breve descrizione del processo. Dalla finestra di dialogo Proprietà (scheda Generale) si ottengono invece informazioni più dettagliate sul file eseguibile: tipo di file, descrizione, percorso completo sul disco (es. `C:\Windows\System32`), dimensione e dimensione su disco, date di creazione/modifica/ultimo accesso e attributi del file (sola lettura, nascosto). Le altre schede della finestra Proprietà (Firme digitali, Sicurezza, Dettagli, Versioni precedenti) permettono inoltre di verificare la firma digitale dell'eseguibile, i permessi di sicurezza e informazioni di versione più approfondite – dati particolarmente utili in un contesto di analisi di sicurezza per verificare la legittimità di un processo.

Parte 5: Svuotare il cestino usando PowerShell

Prima dell'operazione, il Cestino conteneva tre elementi (un file di testo e due cartelle di prova).

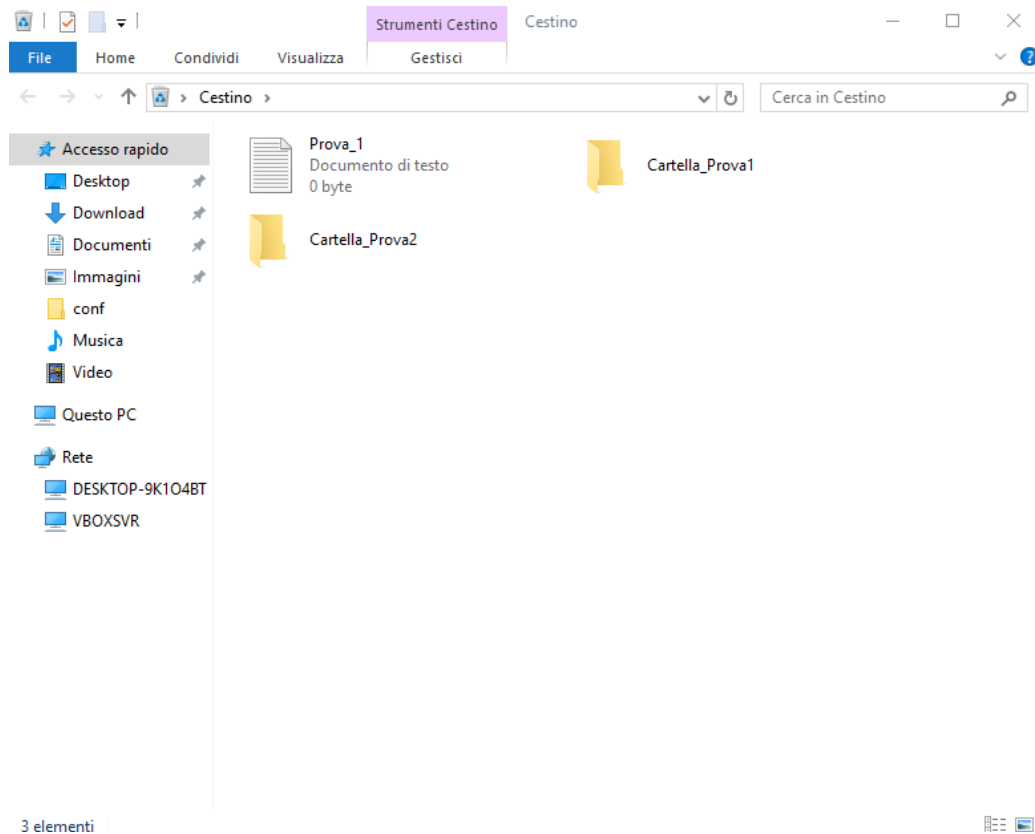


Figura 8: Contenuto del Cestino prima dello svuotamento.

È stato quindi eseguito il comando `clear-recyclebin` da una console PowerShell con privilegi elevati.

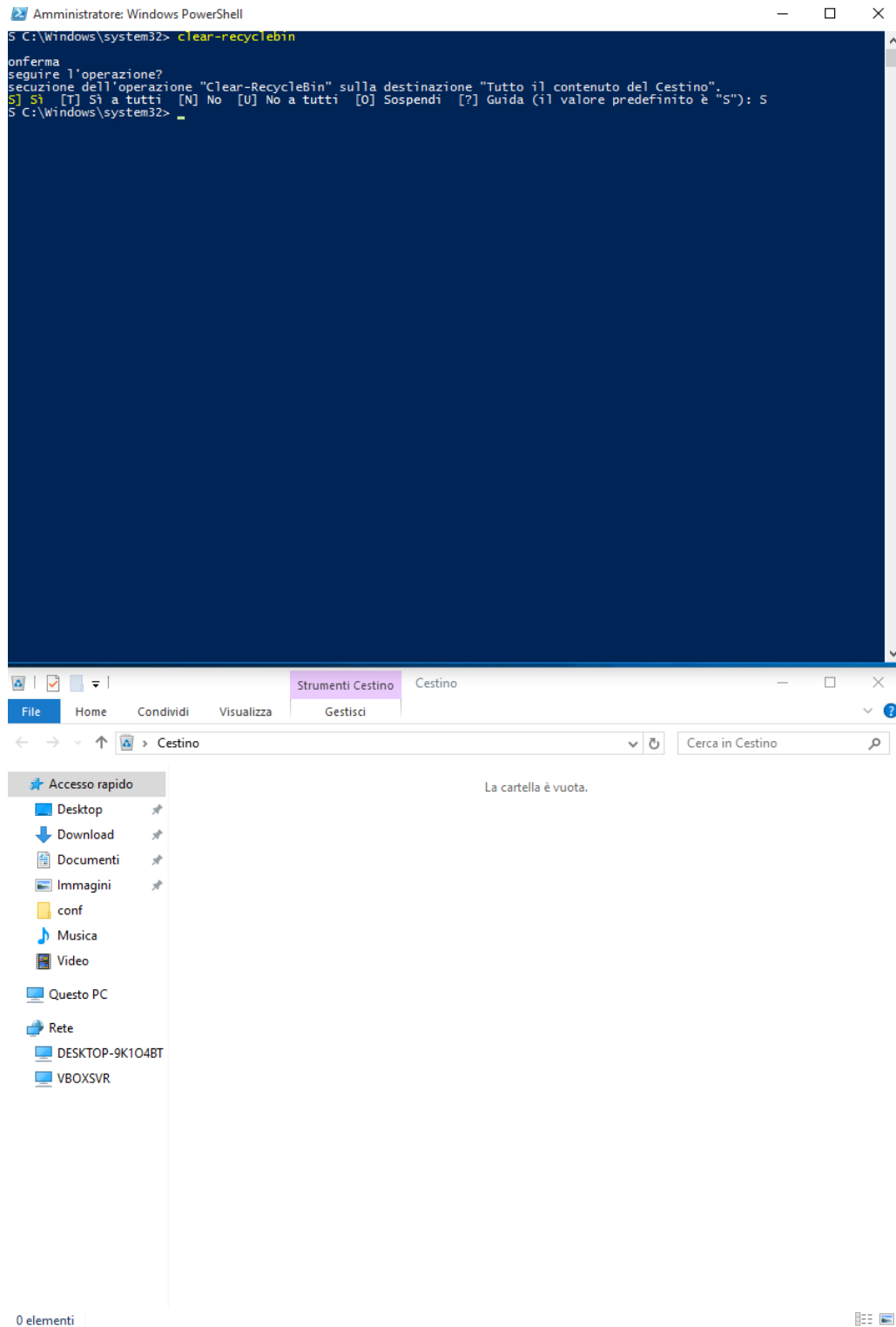


Figura 9: Esecuzione di `clear-recyclebin` e stato del Cestino dopo l'operazione.

Domanda: *Cosa è successo ai file nel Cestino?*

Risposta: Dopo aver confermato l'operazione (digitando S alla richiesta di conferma), tutti gli elementi presenti nel Cestino sono stati eliminati in modo permanente dal sistema. Confrontando lo stato del Cestino prima (Prova_1 e le cartelle Cartella_Prova1,

Cartella_Prova2, per un totale di 3 elementi) e dopo l'esecuzione di `clear-recyclebin` (Cestino vuoto, "La cartella è vuota"), si osserva che il comando ha svuotato completamente il Cestino, rendendo i file non più recuperabili tramite la normale interfaccia di ripristino.

Domanda di Riflessione

Domanda: *PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Usando internet, ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza. Registra le tue scoperte.*

Risposta: PowerShell offre numerosi cmdlet utili per semplificare le attività quotidiane di un analista di sicurezza. Alcuni esempi rilevanti individuati tramite ricerca:

- `Get-Process` e `Stop-Process`, per monitorare e terminare processi sospetti;
- `Get-NetTCPConnection`, l'equivalente nativo PowerShell di `netstat`, che restituisce oggetti facilmente filtrabili e ordinabili (es. `Get-NetTCPConnection | Where-Object State -eq 'Listen'`);
- `Get-WinEvent`, per interrogare e filtrare i log degli eventi di Windows alla ricerca di attività anomale;
- `Test-NetConnection`, per verificare rapidamente la raggiungibilità di host e porte specifiche, in sostituzione combinata di `ping` e `telnet`;
- `Get-LocalUser` e `Get-LocalGroupMember`, per controllare rapidamente utenti e appartenenze ai gruppi locali, utile per individuare account non autorizzati;
- `Invoke-Command`, per eseguire comandi o script su più macchine remote contemporaneamente tramite PowerShell Remoting, particolarmente utile per attività di hardening o triage su larga scala.

Questi strumenti dimostrano come PowerShell, nato per l'automazione dei task amministrativi, si presti altrettanto bene a compiti di sicurezza operativa quali monitoraggio, auditing e risposta rapida agli incidenti.

Bonus 1: Esplorazione di Nmap

Parte 1: Esplorazione di Nmap

Per approfondire lo strumento Nmap è stata consultata la relativa pagina di manuale con `man nmap`.

Domanda: *Cos'è Nmap?*

Risposta: Nmap (*Network Mapper*) è uno strumento open source per l'esplorazione della rete e l'audit di sicurezza, progettato per scansionare rapidamente reti di grandi dimensioni, sebbene funzioni altrettanto bene contro singoli host.

Domanda: *Per cosa viene usato nmap?*

Risposta: Nmap utilizza pacchetti IP grezzi per determinare quali host sono disponibili sulla rete, quali servizi (nome e versione dell'applicazione) tali host offrono, quali sistemi operativi (e relative versioni) sono in esecuzione, che tipo di filtri di pacchetti/firewall sono in uso, oltre a numerose altre caratteristiche. È comunemente impiegato per audit di sicurezza, gestione degli aggiornamenti dei servizi e monitoraggio della disponibilità di host e servizi.

Domanda: *Qual è il comando nmap usato?*

Risposta: Il comando riportato nell'Esempio 1 della pagina di manuale è: `nmap -A -T4 scanme.nmap.org`.

Domanda: *Cosa fa l'opzione -A?*

Risposta: Abilita il rilevamento del sistema operativo (OS detection), il rilevamento delle versioni dei servizi (version detection), lo script scanning e il traceroute.

Domanda: *Cosa fa l'opzione -T4?*

Risposta: Imposta il timing template della scansione su un livello più aggressivo (la scala va da -T0, il più lento e furtivo, a -T5, il più rapido), riducendo i tempi di attesa tra i pacchetti per un'esecuzione più veloce.

Parte 2: Scansione delle Porte Aperte

Passo 1: Scansiona il tuo localhost. Il primo tentativo di scansione (`nmap -A -T4 localhost`) non ha prodotto risultati completi a causa di un refuso nei trattini delle opzioni (lo stesso problema di "trattini intelligenti" già riscontrato nel corso del laboratorio), che ha impedito il riconoscimento di `-A` e `-T4`. Contestualmente, tramite `ip address` è stato confermato l'indirizzo IPv4 della VM: `10.0.2.15/24`.

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 06:33 -0400
Failed to resolve "-A".
Failed to resolve "-T4".
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ovs-system: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether ce:33:b2:6b:f5:4d brd ff:ff:ff:ff:ff:ff
3: s1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 96:3e:86:72:de:49 brd ff:ff:ff:ff:ff:ff
4: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 86276sec preferred_lft 86276sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86279sec preferred_lft 14279sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

Figura 10: Primo tentativo di scansione con refuso nelle opzioni, e verifica dell'indirizzo IP con `ip address`.

Ripetendo correttamente il comando (`nmap -A -T4 10.0.2.15/24`) sono stati ottenuti i risultati completi.

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.15/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 06:40 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000023s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 3
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_--Iw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 56.96 seconds
[analyst@secOps ~]$
```

Figura 11: Scansione completa dell'host locale con opzioni `-A -T4` correttamente riconosciute.

Domanda: *Quali porte e servizi sono aperti? Per ognuna delle porte aperte, registra il*

software che fornisce i servizi.

Risposta: Risultano aperte due porte:

- **21/tcp – FTP:** servizio `vsftpd 2.0.8` or later, con login anonimo consentito (FTP code 230) e un file di prova (`ftp_test`) presente sul server;
- **22/tcp – SSH:** servizio `OpenSSH 10.0` (protocollo 2.0).

Passo 2: Scansiona la tua rete. Domanda: *A quale rete appartiene la tua VM?*

Risposta: La VM appartiene alla rete **10.0.2.0/24** (indirizzo IP 10.0.2.15, subnet mask 255.255.255.0, come confermato dall'output di `ip address` in Figura 10).

Domanda: *Quanti host sono attivi? Dai risultati di Nmap, elenca gli indirizzi IP degli host che si trovano sulla stessa LAN della tua VM. Elenca alcuni dei servizi disponibili sugli host rilevati.*

Risposta: Dalla scansione della rete 10.0.2.0/24 (256 indirizzi scansionati, Figura 11) risulta **un solo host attivo:** 10.0.2.15, corrispondente alla VM stessa. Non sono stati individuati altri host sulla rete NAT di VirtualBox. I servizi disponibili su tale host sono gli stessi identificati nel Passo 1: FTP (`vsftpd 2.0.8`, login anonimo consentito) e SSH (`OpenSSH 10.0`).

Passo 3: Scansiona un server remoto. Domanda: *Qual è lo scopo di questo sito?*

Risposta: `scanme.nmap.org` è un server messo a disposizione ufficialmente dal progetto Nmap stesso, proprio per consentire agli utenti di esercitarsi con lo strumento e testarne le funzionalità senza effettuare scansioni non autorizzate verso host di terzi.

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 06:47 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.21s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
80/tcp    open  tcpwrapped
31337/tcp open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 81.92 seconds
[analyst@secOps ~]$
```

Figura 12: Scansione di `scanme.nmap.org` con `nmap -A -T4`.

Domanda: *Quali porte e servizi sono aperti?*

Risposta: Risultano aperte due porte, entrambe identificate genericamente come `tcpwrapped` (Nmap non è riuscito a determinare con certezza il servizio applicativo in esecuzione): **80/tcp** e **31337/tcp**.

Nota: il risultato ottenuto differisce dall'esempio storico riportato nella pagina di manuale (Figura ??), dove la porta 80 veniva identificata chiaramente come Apache httpd e la porta 22 come OpenSSH. Questo suggerisce un probabile irrigidimento (hardening) o l'introduzione di un firewall/proxy sul server nel tempo trascorso dalla pubblicazione dell'esempio originale.

Domanda: *Quali porte e servizi sono filtrati?*

Risposta: L'output non elenca singolarmente porte filtrate, ma riporta la dicitura "Not shown: 998 filtered tcp ports (no-response)": 998 porte su 1000 risultano quindi filtrate, in quanto non hanno generato alcuna risposta al probe di Nmap – comportamento tipico di un firewall che scarta silenziosamente i pacchetti anziché rispondere con un segmento RST.

Domanda: *Qual è l'indirizzo IP del server?*

Risposta: L'indirizzo IPv4 del server è **45.33.32.156**. È presente anche un indirizzo IPv6 (2600:3c01::f03c:91ff:fe18:bb2f), non scansionato in questa esecuzione.

Domanda: *Qual è il sistema operativo?*

Risposta: Non è stato possibile determinarlo con certezza: l'output della scansione non contiene alcuna riga di rilevamento del sistema operativo (assenti i campi `OS details/Running`), a differenza dell'esempio storico della pagina di manuale che riportava Linux 2.6.X. La causa più probabile è che le poche porte aperte identificate come `tcpwrapped` non abbiano fornito a Nmap fingerprint sufficienti per un rilevamento OS affidabile.

Domanda di Riflessione

Domanda: *Nmap è uno strumento potente per l'esplorazione e la gestione della rete. Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?*

Risposta: Dal punto di vista difensivo, Nmap permette a un amministratore o analista di sicurezza di mantenere un inventario aggiornato dei dispositivi e servizi esposti sulla rete, individuare porte o servizi non autorizzati, verificare l'efficacia delle regole del firewall e pianificare gli aggiornamenti dei servizi vulnerabili prima che vengano sfruttati.

Dal punto di vista offensivo, lo stesso strumento costituisce la base della fase di *ricognizione* (reconnaissance) di un attacco: un attore malevolo può utilizzarlo per mappare la topologia di una rete target, identificare host attivi, porte aperte e versioni software specifiche – informazioni poi utilizzate per individuare vulnerabilità note (CVE) associate a quelle versioni e pianificare exploit mirati o strategie di movimento laterale all'interno della rete compromessa.

Bonus 2: Attacco a un database MySQL

Parte 1: Aprire Wireshark e caricare il file PCAP

È stato caricato in Wireshark il file `SQL_Lab.pcap`, contenente la cattura di un attacco di SQL injection della durata di 441 secondi.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=45838 TSecr=38535
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=45838 TSecr=38535
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=45838 TSecr=38535
4	0.000681	10.0.2.4	10.0.2.15	HTTP	654	POST /dvwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 → 35614 [ACK] Seq=1 Ack=589 Win=30208 Len=0 TSval=38536 TSecr=45838
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSecr=38536
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=38536
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429	GET /dvwa/dvwa/css/main.css HTTP/1.1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.1
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80 → 35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82101 TSecr=98114
15	174.257980	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dvwa/vulnerabilities/sqli/?id=1%27*or*%270%3D0%270&Submit=Submit HTTP/1.1
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80 → 35640 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93660 TSecr=111985

Figura 13: Elenco dei pacchetti della cattura `SQL_Lab.pcap`.

Domanda: Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

Risposta: I due indirizzi IP coinvolti sono **10.0.2.4** (l'attaccante, che invia le richieste HTTP contenenti i payload di SQL injection) e **10.0.2.15** (la vittima, il server web che ospita l'applicazione vulnerabile DVWA – *Damn Vulnerable Web Application*).

Parte 2: Visualizzare l'attacco di SQL Injection

Seguendo il flusso HTTP dello stream 1, si osserva il primo test dell'aggressore: la query `id=1=1` inserita nel campo UserID.



Figura 14: Follow HTTP Stream (stream 1): primo test di SQL injection con la query 1=1.

Invece di restituire un messaggio di errore, l'applicazione risponde con un record del database (First name: admin, Surname: admin), confermando che l'input non viene validato correttamente e che il campo è vulnerabile a SQL injection.

Parte 3: L'attacco di SQL Injection continua

Nello stream 3, l'aggressore invia la query `1' or 1=1 union select database(), user()#`, ottenendo in risposta il nome del database e l'utente MySQL in uso, oltre a diversi record aggiuntivi.

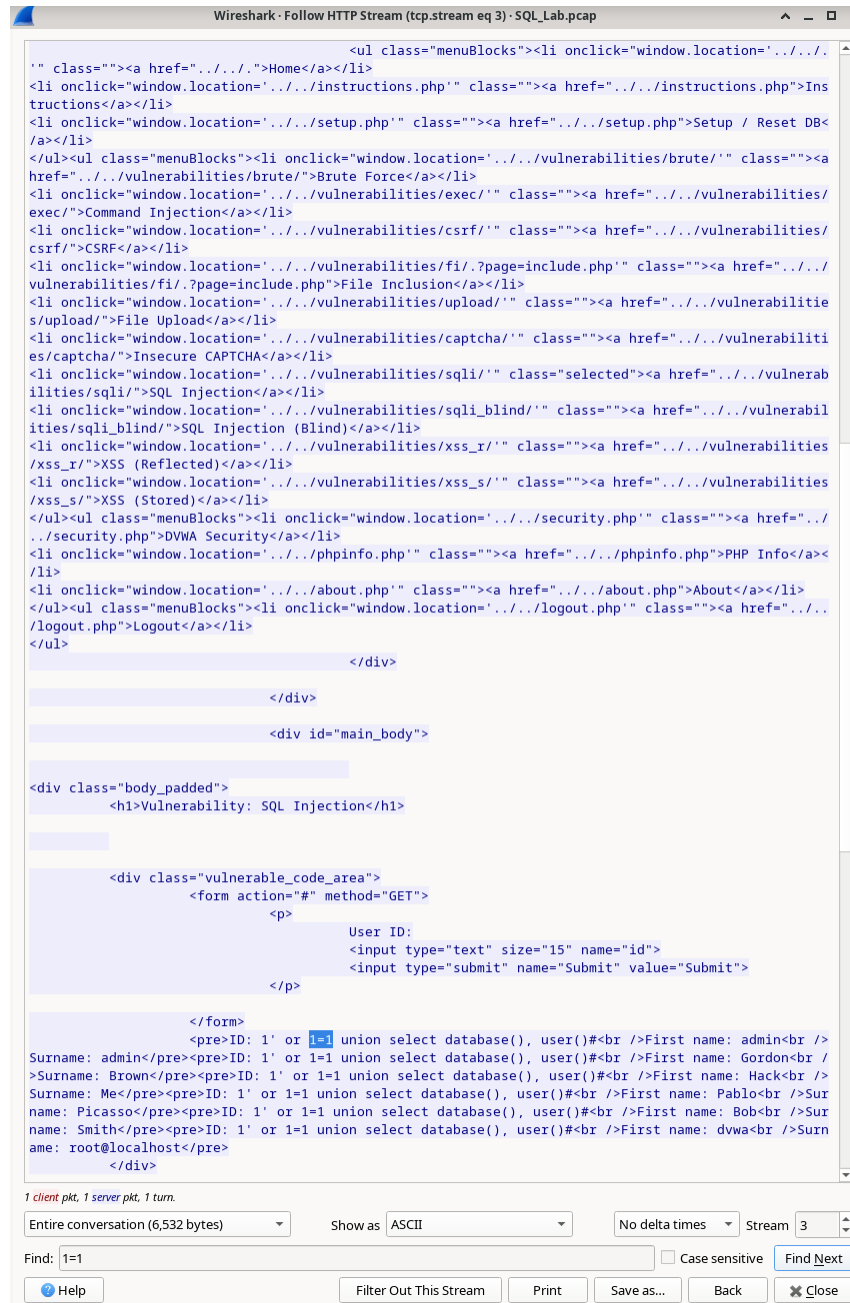


Figura 15: Follow HTTP Stream (stream 3): estrazione del nome del database e dell'utente MySQL.

Il nome del database estratto è `dvwa` e l'utente del database è `root@localhost`; vengono inoltre visualizzati più account utente dell'applicazione (Gordon Brown, Hack Me, Pablo Picasso, Bob Smith).

Parte 4: L'attacco di SQL Injection fornisce informazioni di sistema

Con la query `1' or 1=1 union select null, version()#` (stream 4), l'aggressore individua la versione del DBMS in uso.



Figura 16: Follow HTTP Stream (stream 4): estrazione della versione di MySQL.

Domanda: *Cosa farebbe per l'aggressore il comando modificato di 1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'?*

Risposta: Il database risponderebbe con un output molto più breve rispetto all'enumerazione completa delle tabelle, filtrato esclusivamente per la tabella **users**: anziché elencare i nomi di tutte le tabelle del database, la query interroga **INFORMATION_SCHEMA.columns** e restituirebbe unicamente i nomi delle colonne che compongono la tabella **users** (ad esempio **user_id**, **user**, **password**, **avatar**), fornendo così all'aggressore la struttura esatta della tabella da colpire nel passo successivo.

Parte 6: L'attacco di SQL Injection si conclude

Nello stream 6, l'aggressore invia la query `1' or 1=1 union select user, password from users#`, ottenendo l'elenco completo di nomi utente e hash delle rispettive password.



Figura 18: Follow HTTP Stream (stream 6): estrazione di nomi utente e hash delle password dalla tabella users.

Domanda: Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?

Risposta: L'hash 8d3533d75ae2c3966d7e0d4fcc69216b appartiene all'utente **1337**.

Utilizzando il servizio online Crackstation, l'hash è stato sottoposto a cracking.

hashes: 1 cracked: 1 partial: 0 not found: 0 invalid: 0			
Hash	Type	Result	
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley	

Figura 19: Risultato del cracking dell'hash tramite Crackstation.

Domanda: *Qual è la password in chiaro?*

Risposta: La password in chiaro, ottenuta tramite Crackstation, è **charley**. Il fatto che un hash MD5 non salato (privo di salt) sia stato craccato istantaneamente tramite un semplice lookup online dimostra la debolezza intrinseca di MD5 come algoritmo per la memorizzazione di password, oggi considerato del tutto inadeguato a tale scopo.

Domande di Riflessione

Domanda: *Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?*

Risposta: La grande maggioranza delle applicazioni web moderne si appoggia a database relazionali interrogati tramite SQL: questa diffusione capillare rende la SQL injection una delle classi di vulnerabilità più impattanti e ricorrenti, poiché una singola falla di validazione dell'input può esporre l'intero contenuto del database (credenziali, dati personali, informazioni di business) e, a seconda dei permessi dell'utente del database, permettere anche la modifica o cancellazione dei dati. La gravità concreta di un attacco dipende dai privilegi dell'account database utilizzato dall'applicazione e dalle competenze dell'aggressore.

Domanda: *Naviga in internet ed esegui una ricerca per "prevenire attacchi di SQL injection". Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?*

Risposta: Due tra i metodi più efficaci individuati sono:

1. **Query parametrizzate (prepared statement):** anziché concatenare direttamente l'input dell'utente all'interno della stringa SQL, i valori vengono passati come parametri separati dal motore del database, che li tratta sempre come dati e mai come codice eseguibile – questo impedisce strutturalmente che un input malevolo alteri la logica della query.
2. **Web Application Firewall (WAF):** un livello di protezione perimetrale che analizza le richieste HTTP in ingresso e blocca pattern tipici di SQL injection (es. UNION SELECT, commenti SQL # o -) prima che raggiungano l'applicazione, fungendo da ulteriore livello di difesa oltre alla corretta scrittura del codice.